

SQL Injection en ASP.NET Core

Buscar admin, user1 y un valor inexistente.

VulnerableApp Home Privacy

Buscar Usuarios

Username	Email	Balance
user1	user@test.com	\$500.00

VulnerableApp Home Privacy

Buscar Usuarios

Username	Email	Balance
admin	admin@test.com	\$1000.00

VulnerableApp Home Privacy

Buscar Usuarios

Entrada manipulada:

VulnerableApp Home Privacy

Buscar Usuarios

Username	Email	Balance
admin	admin@test.com	\$1000.00
user1	user@test.com	\$500.00
user2	user2@test.com	\$750.00

Código vulnerable:

Se encuentra exactamente en controllers/SearchController.cs

```
string query = "SELECT * FROM Users WHERE Username LIKE '%" + search + "%'";  
var users = _db.Users.FromSqlRaw(query).ToList();
```

El problema es que la variable search se concatena directamente dentro de la consulta SQL, eso provoca que la entrada del usuario sea interpretada como parte del comando SQL, permitiendo modificar su estructura.

Explicación de la consulta resultante

El servidor toma la base "SELECT * FROM Users WHERE Username LIKE '%" y le pega el texto que se pone en el search, dando: SELECT * FROM Users WHERE Username LIKE '% ' OR '1'='1%'. El primer apóstrofo (') cierra antes de tiempo la condición que había creado el sistema. Esto hace que la base de datos deje de interpretar toda la entrada como un simple texto. El símbolo % en SQL significa "cualquier texto". Al agregar OR, se le indica a la base de datos que basta con que una de las condiciones sea verdadera para devolver un resultado. Como la primera condición ya es verdadera para todos los registros, el filtro deja de funcionar y la base de datos devuelve toda la información disponible.